

## Introduction à la méthode EBIOS

La **méthode EBIOS** (Expression des Besoins et Identification des Objectifs de Sécurité) est un cadre méthodologique élaboré pour analyser et gérer les risques liés à la cybersécurité. Développée en France par l'ANSSI (Agence Nationale de la Sécurité des Systèmes d'Information), elle est largement utilisée pour accompagner les organisations dans la compréhension, l'évaluation et la maîtrise des risques affectant leurs systèmes d'information.

EBIOS se distingue par son approche structurée, qui s'articule autour de l'identification des besoins de sécurité et la mise en œuvre de mesures adaptées à chaque contexte organisationnel. Cette méthode est particulièrement pertinente dans un environnement où les menaces cyber évoluent rapidement, nécessitant une gestion proactive et adaptable des risques.

## Objectifs de la méthode EBIOS

EBIOS vise plusieurs objectifs clés :

1. **Identifier et évaluer les risques** : Comprendre les menaces, vulnérabilités et impacts associés à l'écosystème numérique d'une organisation.
2. **Rendre les décisions stratégiques plus éclairées** : Fournir aux décideurs une vue claire des priorités en matière de cybersécurité.
3. **Structurer les plans d'action** : Élaborer des mesures de sécurité adaptées, proportionnées et alignées sur les besoins métiers.
4. **Assurer la conformité réglementaire** : Notamment avec des normes telles que l'ISO/IEC 27001 ou les exigences européennes comme le RGPD.

## Les étapes clés de la méthode

La méthode EBIOS se décompose en plusieurs phases, chacune contribuant à une compréhension approfondie des risques :

1. **Cadre du risque** : Définir le périmètre d'analyse et le contexte (organisationnel, technique, réglementaire).
2. **Scénarios stratégiques** : Identifier les menaces globales et les scénarios pouvant impacter les actifs critiques.
3. **Scénarios opérationnels** : Analyser les chaînes de compromission, c'est-à-dire les enchaînements d'événements menant à une atteinte à la sécurité.
4. **Évaluation des risques** : Prioriser les scénarios en fonction de leur vraisemblance et de leur impact.
5. **Stratégie de traitement des risques** : Proposer des solutions pour réduire, transférer ou accepter les risques identifiés.

## Points forts de la méthode EBIOS

- **Flexibilité** : Elle peut être appliquée à tout type d'organisation, quelle que soit sa taille ou son secteur d'activité.
- **Interopérabilité** : Compatible avec d'autres normes ou méthodologies (ISO 27005, NIST, etc.).
- **Approche collaborative** : Encourage la participation des parties prenantes, y compris les experts métiers et techniques, pour une analyse exhaustive.
- **Centrée sur les scénarios** : Met l'accent sur des cas concrets et spécifiques, facilitant ainsi leur compréhension et leur gestion.

En somme, EBIOS est un outil puissant pour sécuriser les systèmes d'information en intégrant la gestion des risques au cœur des processus organisationnels. Cela permet non seulement de protéger les actifs critiques, mais également d'assurer la résilience face aux menaces futures.

### Quelques scénarios d'usage

## Conformité RGPD dans un cabinet médical

**Contexte** : Un cabinet stocke les données de ses patients sur un logiciel de gestion médicale.

**Objectif** : Protéger les données sensibles et se conformer au RGPD.

- **Cadre du risque** : Inclut le logiciel, les postes de travail et les sauvegardes des données.
- **Scénarios stratégiques** : Vol ou perte des données médicales (par exemple, par un ransomware ou une erreur humaine).
- **Scénarios opérationnels** : Une clé USB contenant des données non chiffrées est perdue par un collaborateur.
- **Évaluation des risques** : Probabilité élevée pour une erreur humaine, impact critique pour la confidentialité des patients.
- **Traitement des risques** : Chiffrement des données sensibles, formation des utilisateurs, et adoption d'une politique stricte sur les sauvegardes.

## Sécuriser un système de télétravail

**Contexte** : Une entreprise a adopté une solution de télétravail, avec des employés utilisant des VPN pour accéder aux données internes.

**Objectif** : Identifier et traiter les risques liés à cette configuration.

- **Cadre du risque** : Définir le périmètre de l'analyse (accès aux données sensibles via le VPN).
- **Scénarios stratégiques** : Identifier les menaces majeures, comme le vol de données via un piratage de VPN ou une compromission des terminaux personnels.
- **Scénarios opérationnels** : Analyser les chaînes d'attaque possibles, comme l'envoi d'un lien de phishing à un employé pour voler ses identifiants VPN.
- **Évaluation des risques** : Estimer la probabilité (haut risque si le personnel n'est pas formé) et l'impact (critique si des données sensibles sont exposées).
- **Traitement des risques** : Implanter l'authentification multi-facteurs (MFA), former les employés à reconnaître les tentatives de phishing, et sécuriser les appareils utilisés.